

RAPPORT DE TP 2

vCenter Server & Proxmox Datacenter

Administration centralisée et cybersécurité

Module : Virtualisation & Cloud — Cybersécurité
1ère année Cybersécurité — 2025/2026

1. Introduction

Ce second TP fait suite au premier TP, où nous avons installé ESXi et Proxmox VE en environnement nested sous VMware Workstation. L'objectif de ce TP était de passer de l'administration d'un hôte isolé à une administration centralisée : déployer vCenter Server (VCSA) pour fédérer notre hôte ESXi dans une structure Datacenter/Cluster, et explorer en profondeur la vue Datacenter de Proxmox (stockage, pools, permissions, firewall, sauvegardes). L'angle cybersécurité (RBAC, segmentation réseau, journalisation, NTP) a été présent à chaque étape.

2. Partie C — vCenter Server

2.1 Déploiement de VCSA

Le déploiement de vCenter Server Appliance (VCSA) a été réalisé à partir de l'ISO VMware-VCSA-all-*.iso, en lançant l'installateur (vcsa-ui-installer). Nous avons choisi Install avec le type Embedded Platform Services Controller, en ciblant notre hôte ESXi (IP et identifiants root). La VM VCSA a été nommée vcsa-cyber-lab, taille Tiny (2 vCPU, 12 Go RAM), stockée sur le datastore local en Thin Disk Mode, connectée au port group VM Network. Une IP statique, le DNS et le NTP ont été configurés, ainsi que le domaine SSO vsphere.local.

Après environ 30-45 minutes de déploiement (les services VCSA prennent du temps à démarrer au premier boot), l'accès à https://<IP_VCSA> a affiché la page de connexion vSphere Client, où nous nous sommes connectés avec administrator@vsphere.local. Le certificat auto-signé a généré l'avertissement habituel du navigateur, accepté pour le lab.

2.2 Création de la hiérarchie Datacenter / Cluster / Hôte

Une fois connectés au vSphere Client, l'inventaire était vide. Nous avons créé un Datacenter nommé CYBER-DC (clic droit sur la racine vCenter → New Datacenter), puis un Cluster CYBER-CLUSTER à l'intérieur (DRS et HA laissés désactivés, car un seul hôte ne permet ni migration ni haute disponibilité).

Notre hôte ESXi a ensuite été ajouté au cluster via Add Host, en saisissant son IP et les identifiants root, puis en acceptant l'alerte de certificat (thumbprint). L'hôte est apparu sous CYBER-CLUSTER avec le statut Connected, et son onglet Summary affiche le CPU, la RAM et les datastores.

2.3 Organisation de l'inventaire (Folders)

En vue VMs and Templates, trois folders ont été créés sous CYBER-DC : Lab-VMs (VMs de travail), Templates (golden images) et Quarantine (VMs suspectes à isoler). Cette organisation facilite l'application de permissions ciblées et l'audit de l'environnement.

2.4 Création d'une VM de test

La VM cyber-test-01 a été créée dans le folder Lab-VMs, sur la ressource CYBER-CLUSTER, avec stockage sur le datastore local de l'ESXi en Thin Provision, OS Debian (Linux), 1 vCPU, 1 Go de RAM, 10 Go de disque, connectée au port group VM Network, avec l'ISO d'installation montée. Après démarrage, la console a affiché le boot sur l'ISO.

2.5 Snapshots

Un snapshot baseline-clean a été pris sur cyber-test-01 (sans la mémoire, pour rester léger), avec la description 'État propre avant tests de sécurité'. Une modification a ensuite été effectuée dans la VM (création d'un fichier de test), puis le snapshot a été restauré via Manage Snapshots → Revert to. La modification a bien disparu après restauration, confirmant le bon fonctionnement du mécanisme.

2.6 RBAC : permissions et rôles

Un utilisateur student-ops a été créé dans Administration → Single Sign-On → Users and Groups (domaine vsphere.local). Une permission a ensuite été ajoutée sur le folder Lab-VMs : utilisateur student-ops@vsphere.local, rôle Virtual Machine Power User, avec propagation aux enfants.

En se connectant avec ce compte, nous avons vérifié que student-ops peut démarrer/arrêter et accéder à la console de cyber-test-01, mais qu'une action d'infrastructure (par exemple ajouter un hôte) renvoie un message de type 'Permission denied'. Cela illustre concrètement le principe du moindre privilège.

2.7 Logs et événements

Dans l'onglet Monitor → Events des objets (VM, Host, Datacenter), nous avons retrouvé l'historique de nos actions : création du Datacenter, ajout de l'hôte, création de la VM, prise du snapshot et connexion de student-ops, chacune avec un horodatage. L'onglet Tasks liste également toutes les opérations avec leur statut.

Côté configuration (sans forcément l'appliquer), nous avons identifié le paramètre Syslog.global.logHost (Host → Configure → System → Advanced System Settings) qui permettrait d'envoyer les logs vers un serveur syslog externe, ainsi que la configuration NTP dans Host → Configure → System → Time Configuration, indispensable pour des horodatages de logs cohérents.

2.8 Mini-check de sécurité vCenter

- Mot de passe admin SSO robuste : politique vérifiée dans Administration → Configuration.
- SSH sur ESXi : vérifié dans Host → Configure → Services → SSH (à laisser Stopped en dehors du debug).
- NTP configuré : serveur défini dans Time Configuration.
- Lockdown Mode : option identifiée dans Security Profile (non activée en lab).
- Certificat VCSA : présent, auto-signé (normal en lab).
- Permissions : seuls administrator et student-ops présents dans Datacenter → Permissions.
- Logs accessibles : événements récents bien visibles dans Monitor → Events.

3. Partie D — Proxmox Datacenter

3.1 Vue Datacenter

Connectés à https://<IP_Proxmox>:8006 avec root@pam, nous avons parcouru systématiquement les sous-menus de la vue Datacenter : Summary (vue d'ensemble

CPU/RAM/stockage), Cluster (vide, un seul nœud), Options (paramètres globaux), Storage, Backup, Replication, Permissions et Firewall. Au total, plus de 8 sous-menus ont été identifiés, ce qui montre que Proxmox intègre nativement, sans appliance séparée, ce que vCenter propose via VCSA.

3.2 Cluster (concept)

Avec un seul nœud, le clustering Proxmox (basé sur Corosync) n'est pas indispensable : la vue Datacenter fonctionne déjà comme un mini-cluster. La commande `pvecm create CYBER-PVE-CLUSTER` permettrait de créer un cluster à un nœud, mais cela reste optionnel pour notre lab et ne change pas les fonctionnalités disponibles.

3.3 Création d'un Pool

Un pool CYBER-LAB a été créé via Datacenter → Permissions → Pools → Create, avec le commentaire 'Pool pour les VMs et ressources du lab cybersécurité'. Ce pool, équivalent fonctionnel d'un Folder/Resource Pool de vCenter, permet d'appliquer des permissions sur un ensemble de VMs plutôt qu'une par une.

3.4 Stockage

Dans Datacenter → Storage, nous avons retrouvé local (type Directory, pour ISO, templates CT, backups) et local-lvm (type LVM-Thin, pour les disques de VM). Un ISO a été vérifié/téléversé dans local → ISO Images. Les valeurs d'espace total et utilisé de local-lvm ont été notées.

3.5 Création d'une VM

La VM cyber-srv-01 (ID 100) a été créée via Create VM, avec Resource Pool = CYBER-LAB, ISO sélectionnée comme média d'installation, type Linux, disque de 10 Go sur local-lvm, 1 vCPU, 1024 Mo de RAM, et carte réseau VirtIO sur vmbr0. Elle est apparue à la fois sous le nœud et dans le pool CYBER-LAB. Après démarrage, la console a affiché le boot sur l'ISO.

3.6 Snapshots et sauvegarde

Un snapshot baseline-clean (sans la RAM) a été pris sur cyber-srv-01, puis une modification a été effectuée dans la VM, suivie d'un Rollback vers ce snapshot : la modification a bien disparu.

Une sauvegarde manuelle a ensuite été lancée via l'onglet Backup → Backup now, avec stockage sur local, mode Snapshot (à chaud) et compression ZSTD. Le fichier `vzdump-gemu-100-*.vma.zst` est apparu dans local → Backups, confirmant la différence entre un snapshot (rapide, sur le même stockage) et une sauvegarde (copie complète et exportable, stockée séparément).

3.7 RBAC : utilisateurs et rôles

Un utilisateur `student-ops@pve` a été créé (realm Proxmox VE authentication server), puis une permission a été ajoutée sur le chemin `/pool/CYBER-LAB` avec le rôle `PVEVMUser`. En se connectant avec ce compte, nous avons vérifié qu'il ne voit que les VMs du pool CYBER-LAB, peut démarrer/arrêter la VM et ouvrir sa console, mais ne peut pas modifier la configuration du nœud, ajouter du stockage ou modifier le firewall (action refusée constatée).

Le realm PVE a été préféré pour ce compte car il crée un utilisateur interne à Proxmox sans compte Linux associé : `student-ops` ne peut donc pas se connecter en SSH, ce qui est plus sûr pour un compte opérateur.

3.8 Firewall intégré

Nous avons d'abord vérifié que le firewall Datacenter était désactivé (Enable Firewall: No) — l'activer sans règle d'accès au management bloquerait l'accès à l'interface web. Deux règles ACCEPT en entrée ont été ajoutées dans Datacenter → Firewall → Rules : une pour le port 8006/TCP (interface web) et une pour le port 22/TCP (SSH de secours), toutes deux limitées au réseau de management. Le firewall a été laissé désactivé en mode 'test', conformément aux recommandations du TP pour éviter de se bloquer hors de l'interface.

3.9 Logs et tâches

Dans Node → System → Syslog, les messages système sont consultables en temps réel. L'onglet System → Tasks liste l'historique des opérations (création de VM, snapshot, backup, connexions). Depuis le shell Proxmox, la commande `journalctl -u pveproxy --since "1 hour ago"` donne les logs du proxy web, et `/var/log/auth.log` trace les connexions. Nous avons relevé plusieurs événements significatifs : création de la VM 100, prise du snapshot, exécution de la sauvegarde, et connexion de `student-ops@pve`.

4. Partie E — Mini-lab final (Capstone, réalisé sur Proxmox)

Le mini-lab final a été réalisé sur Proxmox VE.

4.1 Réseau isolé

Un nouveau bridge `vmbr1` a été créé dans Node → Network → Create → Linux Bridge, sans interface physique associée (pas d'uplink = réseau totalement isolé). Les deux VMs du capstone ont été connectées à ce bridge.

4.2 Déploiement des VMs

VM	Nom	Configuration	Réseau
Serveur	cyber-srv-cap	1 vCPU, 512 Mo RAM, 8 Go disque	vmbr1 — 10.10.10.1/24
Client	cyber-cli-cap	1 vCPU, 512 Mo RAM, 8 Go disque	vmbr1 — 10.10.10.2/24

Un OS minimal (Debian léger) a été installé sur chaque VM, avec des adresses IP statiques configurées dans le réseau isolé.

4.3 Snapshots de référence

Sur chaque VM, un snapshot `baseline-capstone` a été pris après l'installation et la configuration réseau, représentant l'état sain de référence.

4.4 Incident simulé et restauration

1. Sur `cyber-srv-cap`, une modification volontaire a été effectuée pour simuler une erreur (suppression d'un fichier non critique, `/etc/motd`).
2. Cette modification a été documentée (capture avant/après).
3. Le snapshot `baseline-capstone` a ensuite été restauré (Rollback).
4. Après restauration, le fichier `/etc/motd` était de nouveau présent : l'état est bien revenu à la normale.

Les trois captures (état sain, état altéré, retour à l'état sain) illustrent ce cycle complet.

4.5 Vérification de l'isolation et du RBAC

- Connectivité : ping réussi entre cyber-srv-cap (10.10.10.1) et cyber-cli-cap (10.10.10.2).
- Isolation : aucune des deux VMs n'a accès au réseau de management (vmbr0) ni à Internet, car vmbr1 n'a pas d'uplink physique.
- RBAC : avec le compte student-ops@pve, une action autorisée (démarrer la VM dans le pool CYBER-LAB) fonctionne, tandis qu'une action interdite (modifier le firewall ou ajouter du stockage) est refusée.

4.6 Schéma du mini-lab

Architecture : un bridge isolé vmbr1 (10.10.10.0/24, sans uplink) hébergé sur Proxmox, séparé du bridge de management vmbr0. Deux VMs y sont connectées : cyber-srv-cap (10.10.10.1) avec un snapshot de référence baseline-capstone, et cyber-cli-cap (10.10.10.2) utilisée pour les tests de connectivité. Aucun lien réseau direct n'existe entre vmbr1 et vmbr0/Internet, garantissant que le management reste hors de portée d'une VM compromise sur le réseau isolé.

5. Réponses aux questions d'analyse

Q1 — Surface d'attaque de l'environnement de management

Côté vCenter/ESXi, l'interface VCSA est exposée sur le port 443 (HTTPS, vSphere Client), et l'ESXi sous-jacent expose également le port 443 (Host Client) ainsi que potentiellement le SSH (port 22) s'il est activé. Côté Proxmox, l'interface web est exposée sur le port 8006 (HTTPS) et le SSH sur le port 22. Dans les deux cas, le SSH doit rester désactivé ou restreint sauf besoin ponctuel, et l'accès aux interfaces web doit être limité au réseau de management.

Q2 — Compromission de cyber-srv-cap : accès au management ?

Non. cyber-srv-cap est connectée au bridge isolé vmbr1, qui n'a aucun uplink physique et n'est relié ni à vmbr0 (réseau de management de Proxmox) ni à Internet. Un attaquant ayant compromis cette VM se trouve donc cantonné au réseau 10.10.10.0/24 et ne peut atteindre ni l'interface web Proxmox (port 8006 sur vmbr0), ni l'interface vCenter, ni aucun autre système du réseau de management.

Q3 — Compromission du compte student-ops

Sur vCenter, le rôle Virtual Machine Power User attribué à student-ops permet les opérations courantes sur les VMs (power on/off, console, snapshot) mais pas les opérations d'infrastructure (ajout d'hôte, modification du cluster, suppression de datastore) : l'impact maximal se limite donc à une perturbation des VMs sous Lab-VMs (arrêt, manipulation de snapshots). Sur Proxmox, le rôle PVEVMUser sur /pool/CYBER-LAB limite de la même façon student-ops@pve aux VMs de ce pool, sans accès au nœud, au stockage ou au firewall. Dans les deux cas, l'impact pourrait être réduit davantage en restreignant les permissions à une seule VM plutôt qu'à un pool/folder entier, et en activant une authentification à deux facteurs si disponible.

Q4 — Restauration par snapshot : vCenter vs Proxmox

Sur les deux plateformes, la procédure est similaire dans son principe : sélectionner la VM, ouvrir le gestionnaire de snapshots, choisir le snapshot de référence et lancer la restauration (Revert to sur vCenter, Rollback sur Proxmox). Dans les deux cas, la restauration a été quasi instantanée (quelques secondes), la VM étant arrêtée puis remise dans l'état du snapshot. La principale différence est l'intégration : sur Proxmox, le snapshot et la sauvegarde (vzdump) sont gérés depuis la même interface native, alors que sur vCenter, une vraie sauvegarde nécessiterait un outil tiers (Veeam), le snapshot restant la seule fonctionnalité native testée.

Q5 — Logs permettant de détecter une activité suspecte

Sur vCenter, les onglets Monitor → Events et Tasks de chaque objet permettraient de repérer une connexion inhabituelle (par exemple une connexion de student-ops à une heure anormale) ou une modification de permission non prévue (ajout d'un nouvel utilisateur avec un rôle Administrator). Sur Proxmox, le Syslog du nœud, l'onglet Tasks et le fichier /var/log/auth.log permettraient de repérer une connexion suspecte (échecs répétés, connexion depuis une IP inattendue) ou une modification d'ACL/permission. Dans les deux cas, l'envoi de ces logs vers un serveur syslog/SIEM externe est recommandé pour garantir leur conservation même en cas de compromission de l'hôte.

6. Comparaison vCenter vs Proxmox Datacenter

Critère	vCenter Server	Proxmox VE (Datacenter)
Licence	Payante (sauf évaluation)	Open source (GPL), support payant optionnel
Déploiement management	Appliance séparée (VCSA) sur ESXi	Intégré nativement dans chaque nœud
Ressources management	Lourd : 12+ Go RAM pour VCSA	Léger : interface web sur le nœud, pas de VM en plus
Hierarchie d'objets	Datacenter → Cluster → Host → VM + Folders/Resource Pools	Datacenter → Node → VM/CT + Pools
RBAC	SSO + rôles + permissions par objet, propagation	Realms (PAM/PVE/LDAP) + rôles + ACL par chemin
Réseau virtuel	vSwitch standard/distribué + Port Groups	Bridges Linux (vmbr) + VLAN natifs
Backup intégré	Non (outil tiers requis)	Oui : vzdump, jobs planifiables
Firewall intégré	Non (NSX requis pour micro-segmentation)	Oui, 3 niveaux (Datacenter, Node, VM)
HA / Migration	vMotion, HA, DRS (licences requises)	Live migration (stockage partagé), HA manager
Coût	Élevé (licences par CPU/VM)	Gratuit

Pour un labo cybersécurité ou de pentest, Proxmox est très avantageux : gratuit, backup et firewall intégrés, déploiement léger, snapshots rapides. Pour une PME, Proxmox offre un

excellent rapport fonctionnalités/coût, vCenter restant pertinent si l'entreprise est déjà investie dans l'écosystème VMware. Pour un SOC ou une grande entreprise, vCenter associé à NSX apporte une micro-segmentation avancée et s'intègre aux outils de sécurité VMware, tandis que Proxmox peut alimenter un SOC via ses API et son syslog.

7. Questions techniques complémentaires

QT1 — vSwitch Standard vs vSwitch Distribué

Le vSwitch Standard (vSS) est configuré individuellement sur chaque hôte ESXi, de manière indépendante. Le vSwitch Distribué (vDS), disponible uniquement avec une licence vCenter Enterprise Plus, offre une configuration réseau centralisée et cohérente sur plusieurs hôtes. Le vDS devient indispensable dès que l'on gère plusieurs hôtes ESXi et que l'on veut garantir une configuration réseau identique (port groups, VLANs) sur tous, notamment pour permettre le vMotion sans interruption réseau.

QT2 — Realm PVE vs PAM pour les comptes opérateurs

Le realm PVE crée des comptes internes à Proxmox, totalement indépendants des comptes Linux du système. Un utilisateur PVE ne peut donc pas se connecter en SSH ni accéder au shell du nœud, même s'il dispose de droits étendus dans l'interface Proxmox. C'est plus sûr pour des comptes opérateurs : en cas de compromission de leurs identifiants, l'attaquant reste limité à ce que permet l'interface web/API, sans accès direct au système d'exploitation sous-jacent.

QT3 — Importance de la synchronisation NTP

La synchronisation NTP est critique car de nombreux mécanismes de sécurité dépendent d'une horloge fiable. Trois conséquences d'un décalage horaire : premièrement, les journaux (logs) de différents systèmes deviennent impossibles à corréliser correctement, ce qui complique grandement une investigation après incident. Deuxièmement, les certificats TLS peuvent être considérés comme invalides (expirés ou pas encore valides) si l'horloge locale est trop décalée par rapport à l'heure réelle. Troisièmement, des protocoles d'authentification comme Kerberos, utilisés notamment avec Active Directory, échouent si l'écart horaire entre les systèmes dépasse une tolérance stricte (généralement 5 minutes).

QT4 — Compromission du compte administrator@vsphere.local

Avec les identifiants du compte administrator@vsphere.local, un attaquant disposerait d'un contrôle total sur l'ensemble de l'infrastructure gérée par vCenter : création, modification ou suppression de VMs et de datastores, ajout/retrait d'hôtes ESXi, modification des permissions et création de nouveaux comptes administrateurs, accès aux consoles de toutes les VMs (y compris pour exfiltrer des données), et désactivation de mesures de sécurité (firewall, lockdown mode). Des mesures préventives auraient pu limiter cet impact : authentification à plusieurs facteurs sur le compte SSO, limitation stricte du nombre de comptes disposant du rôle Administrator à la racine, restriction de l'accès réseau à l'interface vCenter (VPN/bastion), et surveillance/alerte sur toute action sensible effectuée par ce compte via les logs centralisés.

QT5 — Granularité du firewall : Proxmox vs ESXi (sans NSX)

Le firewall intégré de Proxmox offre, par défaut, une granularité bien supérieure à celle d'ESXi sans NSX : il fonctionne à trois niveaux indépendants (Datacenter, Node, VM/CT), avec des règles spécifiques par machine virtuelle, basées sur les interfaces réseau virtuelles. ESXi

dispose d'un firewall hôte basique, principalement orienté vers la protection des services de management de l'hôte lui-même (SSH, interface web), sans contrôle fin du trafic entre VMs. Pour obtenir une micro-segmentation comparable sous VMware, il faut ajouter NSX, qui est un produit séparé et payant. Par défaut, Proxmox offre donc plus de contrôle réseau granulaire sans coût supplémentaire.

8. Conclusion

Ce TP nous a permis de passer de l'administration d'un hôte isolé à une gestion centralisée sur les deux plateformes. Avec vCenter, nous avons déployé l'appliance VCSA, construit une hiérarchie Datacenter/Cluster/Folders, ajouté notre hôte ESXi, créé une VM, manipulé des snapshots et configuré un RBAC de base avec le compte student-ops. Avec Proxmox, nous avons exploré la vue Datacenter intégrée (stockage, pools, permissions, firewall, logs), créé une VM dans un pool dédié, testé snapshots et sauvegardes, et configuré un RBAC équivalent avec student-ops@pve.

Le mini-lab final, réalisé sur Proxmox, a concrétisé l'ensemble : un réseau isolé (vmbr1) hébergeant deux VMs, un snapshot de référence, un incident simulé suivi d'une restauration réussie, et la vérification que ni l'isolation réseau ni le RBAC ne pouvaient être contournés par un utilisateur à privilèges limités.

La comparaison entre vCenter et Proxmox Datacenter montre que les concepts fondamentaux (hiérarchie d'objets, RBAC, segmentation réseau, journalisation, snapshots/sauvegardes) sont communs aux deux écosystèmes, mais que Proxmox les intègre nativement et gratuitement, alors que vCenter nécessite une appliance lourde et des licences payantes pour atteindre un niveau de fonctionnalités équivalent (notamment le firewall et le backup intégrés). Pour un contexte académique ou de pentest, Proxmox reste donc le choix le plus pratique, tandis que vCenter demeure la référence dans les grands environnements déjà investis dans l'écosystème VMware.